

PIEDMONT MEDICAL GROUP

Capstone Project: Threat Intelligence Brief and SOC Enhancement Plan



MEDICAL
CENTRE

Created By: Paul Leone

October 6, 2025

1 TABLE OF CONTENTS

2	Threat Intelligence Brief	3
2.1	Purpose	3
2.2	Overview of UNC5221 Threat Landscape	3
2.2.1	Background	3
2.2.2	Related Campaigns	3
2.3	Threat Analysis – Ivanti Connect Secure	4
2.3.1	Vulnerabilities Overview	4
2.3.2	Related Toolset.....	6
2.3.3	MITRE ATT&CK Mapping for Ivanti CVEs	7
2.3.4	Risk Assessment	10
2.3.5	Recommendations for Mitigation and Detection.....	10
3	Security Operations Center - Detection Strategy and Rule Deployment	13
3.1	Purpose	13
3.2	Critical Log Sources and Telemetry.....	13
3.2.1	Critical Log Sources	13
3.2.2	MITRE Technique Telemetry Coverage	14
3.3	Detection Rule suggestions.....	15
3.3.1	YARA Rules for Detection	15
3.3.2	Suricata Intrusion Prevention System Detection Rules	16
3.3.3	SentinalOne	17
3.3.4	CrowdSec Detection Scenarios.....	17
3.3.5	Firewall Filter Rules	19
3.3.6	File Integrity Monitoring (FIM)	20
3.3.7	Passive DNS and Proxy Analysis	20
3.3.8	Sigma Rules and Splunk Correlation Logic	21
3.4	Workflow and Feature Enhancements to Existing Solutions	24
3.4.1	SentinalOne Singularity Endpoint.....	24
3.4.2	SOAR Playbooks.....	25
3.4.3	Threat Intelligence Integration.....	25
3.4.4	Passive DNS and Proxy Analysis	26
3.4.5	Integration Notes	26
3.5	New Platform and Technology Acquisitions.....	26
3.5.1	CrowdSec Threat Intelligence	26
3.5.2	Splunk SOAR	27
3.5.3	DLP solution.....	28

2 THREAT INTELLIGENCE BRIEF

2.1 PURPOSE

This brief delivers a focused overview of UNC5221, a threat actor that presents significant risks to Piedmont Medical Group (PMG) and the broader healthcare sector. The purpose of this document is to inform PMG's IT team and healthcare staff by providing context, analysis, and tailored recommendations based on PMG's specific IT environment and operational needs.

To begin, the background summary will contextualize UNC5221's activities and objectives in the healthcare industry. Following the background summary, the threat analysis will detail how UNC5221's tactics, techniques, and procedures (TTPs) align with the MITRE ATT&CK framework. The MITRE ATT&CK framework is a globally recognized knowledge base that categorizes adversary tactics and techniques observed in real-world incidents.

After the threat analysis, the report will summarize the vulnerabilities most relevant to PMG, with a focus on those affecting the organization's technology stack and network. This section will make clear how these vulnerabilities could impact PMG's infrastructure.

Building on the vulnerabilities discussion, the document will address the malware toolkits deployed by UNC5221, explaining their potential effects on PMG's systems. The report will then conclude with actionable recommendations for detection and mitigation, all of which are customized to address the unique IT infrastructure and operational requirements of Piedmont Medical Group.

As a follow-up, a Security Operations Center (SOC) detection strategy and rule deployment document will be provided to the IT team for further review. This accompanying document will include: an inventory of critical log sources and telemetry for PMG's assets; detection rule suggestions mapped to the observed TTPs; and proposed enhancements for dashboards and SOC workflows, ensuring that all guidance is directly relevant to PMG's environment.

2.2 OVERVIEW OF UNC5221 THREAT LANDSCAPE

2.2.1 Background

UNC5221 is a China-nexus espionage threat actor that the PMG CTI team has been actively tracking since October 2023. This group has increasingly focused its operations on the healthcare sector, targeting critical infrastructure and sensitive patient data within hospitals, clinics, and healthcare service providers.

Their primary initial access vector remains the exploitation of vulnerabilities in widely deployed enterprise-grade Virtual Private Network (VPN) appliances, such as Ivanti Connect Secure. After gaining a foothold, UNC5221 leverages a custom malware toolset designed for stealth and persistent presence within healthcare IT systems.

2.2.2 Related Campaigns

- In April 2025, UNC5221 exploited a critical buffer overflow vulnerability, CVE-2025-22457, in Ivanti Connect Secure VPN appliances.

- Since April 2024, UNC5221 has been observed exploiting vulnerabilities in edge devices, used compromised credentials, and deployed the BRICKSTORM backdoor in a campaign targeting the legal and software industries in the United States (CAMP.25.044)

2.3 THREAT ANALYSIS – IVANTI CONNECT SECURE

This report focuses specifically on PMG and its current VPN infrastructure. At present, PMG's attack surface includes only Ivanti VPN endpoints; Fortinet and Citrix VPN solutions are not deployed within the organization. Accordingly, the analysis will address only Ivanti-specific CVEs and related recommendations.



2.3.1 Vulnerabilities Overview

2.3.1.1 CVE-2023-46805 – Ivanti Connect Secure / Policy Secure Authentication Bypass

- **Overview:** An authentication bypass vulnerability in the web component of Ivanti Connect Secure (ICS) and Ivanti Policy Secure gateways. Allows unauthenticated attackers to access restricted resources by bypassing control checks.
- **Affected Products:**
 - Ivanti Connect Secure
 - Ivanti Policy Secure
 - Ivanti ZTA Gateways
- **Impacted Versions:**
 - Ivanti Connect Secure: 9.x and 22.x (e.g., 9.1R18.3)
 - Ivanti Policy Secure: Same versions
- **Attack Vector:**
 - Remote unauthenticated access via crafted HTTP requests to Ivanti VPN endpoints
- **Exploitation:**
 - Often chained with CVE-2024-21887 for unauthenticated remote code execution.
 - Used by threat actors like UNC5221 and UTA0178 to deploy webshells.
- **Impact**
 - Severity: CVSS 9.8 (Critical)
 - Effect: Full remote code execution without authentication
 - Scope: Allows attackers to deploy malware, establish persistence, and pivot laterally into internal networks
- **Mitigations:**
 - Patch to versions: 9.1R18.4, 9.1R17.3, 22.6R2.2, etc.
 - A patch was released in for ICS 22.2R3 on June 4, 2024. Previous releases were patched on February 8th for Ivanti Connect Secure (versions 9.1R14.5, 9.1R17.3, 9.1R18.4, 22.4R2.3, 22.5R1.2, 22.5R2.3 and 22.6R2.2), Ivanti Policy Secure (versions 9.1R17.3, 9.1R18.4 and 22.5R1.2) and ZTA gateways (versions 22.5R1.6, 22.6R1.5 and 22.6R1.7)) and 14th (for Ivanti Connect Secure (versions 9.1R15.3, 9.1R16.3, 22.1R6.1, 22.2R4.1, 22.3R1.1 and 22.4R1.1) and Ivanti Policy Secure (versions 9.1R16.3, 22.4R1.1 and 22.6R1.1) respectively.

- Ivanti released mitigation scripts for unpatched systems.
- CISA added this to its Known Exploited Vulnerabilities (KEV) catalog.

2.3.1.2 CVE-2024-21887 – Ivanti Command Injection

- **Overview:** A command injection vulnerability in Ivanti ICS and Policy Secure allowing authenticated administrators to execute arbitrary commands.
- **Affected Products:**
 - Ivanti Connect Secure
 - Ivanti Policy Secure
- **Impacted Versions:**
 - Ivanti Connect Secure: 9.x and 22.x (e.g., 9.1R18.3)
 - Ivanti Policy Secure: Same versions
- **Exploitation:**
 - Often chained with CVE-2023-46805 for unauthenticated RCE.
 - Used by UNC5221 and other actors to deploy malware and webshells.
- **Mitigations:**
 - Patch to 9.1R18.4 and other listed versions.
 - Apply Ivanti's mitigation script if patching is delayed.

2.3.1.3 CVE-2025-22457 - Ivanti stack-based buffer overflow

- **Overview:** Stack-based buffer overflow in Ivanti Connect Secure, Policy Secure, and ZTA Gateways
- **Affected Products:**
 - Ivanti Connect Secure
 - Ivanti Policy Secure
 - Ivanti ZTA Gateways
- **Impacted Versions:**
 - Ivanti Connect Secure: 9.x and 22.x (e.g., 9.1R18.3)
 - Ivanti Policy Secure: Same versions
- **Impact:**
 - Remote unauthenticated code execution
 - CVSS: 9.8 (Critical)
 - Exploited In Wild: Yes — attributed to UNC5221 (China-nexus actor)
- **Malware Dropped:**
 - TRAILBLAZE (in-memory dropper)
 - BRUSHFIRE (passive backdoor)
 - SPAWN ecosystem (previously linked to UNC5221)

- **Mitigations:**

- Patch to 9.1R18.4 and other listed versions.
- A patch for CVE-2025-22457 was released in ICS 22.7R2.6 on February 11, 2025. The vulnerability is a buffer overflow with a limited character space, and therefore it was initially believed to be a low-risk denial-of-service vulnerability. We assess it's likely the threat actor studied the patch for the vulnerability in ICS 22.7R2.6 and uncovered through a complicated process, it was possible to exploit 22.7R2.5 and earlier to achieve remote code execution.

2.3.2 Related Toolset

2.3.2.1 Summary

- **Directly Associated:** 3 tools (TRAILBLAZE, BRUSHFIRE, SPAWNSLOTH)
- **Possibly Associated:** 6 tools (SPAWNWAVE, ZIPLINE, Brickstorm, Earthworm, Lightwire, Neo-reGeorg)

2.3.2.2 TRAILBLAZE

TRAILBLAZE is an in-memory only dropper written in bare C that uses raw syscalls and is designed to be as minimal as possible, likely to ensure it can fit within the shell script as Base64. TRAILBLAZE injects a hook into the identified /home/bin/web process. It will then inject the BRUSHFIRE passive backdoor into a code cave inside that process.

- **Threat Correlation:** In-memory dropper deployed via shell injection; fits within login.cgi exploit chain.

2.3.2.3 BRUSHFIRE

BRUSHFIRE is a passive backdoor written in bare C that acts as an SSL_read hook. It first executes the original SSL_read function, and checks to see if the returned data begins with a specific string. If the data begins with the string, it will XOR decrypt then execute shellcode contained in the data. If the received shellcode returns a value, the backdoor will call SSL_write to send the value back.

- **Threat Correlation:** Passive backdoor injected by TRAILBLAZE into /home/bin/web; core persistence mechanism.

2.3.2.4 SPAWNSLOTH

As detailed in our previous blog post, SPAWNSLOTH acts as a log tampering component tied to the SPAWNSNAIL backdoor. It targets the dslogserver process to disable both local logging and remote syslog forwarding.

- **Threat Correlation:** Log tampering component used post-exploitation to disable dslogserver and evade detection.

2.3.2.5 SPAWNWAVE

SPAWNWAVE is an evolved version of SPAWNANT that combines capabilities from other members of the SPAWN* malware ecosystem. SPAWNWAVE overlaps with the publicly reported SPAWNCHIMERA and RESURGE malware families.

- **Threat Correlation:** Part of SPAWN ecosystem; overlaps with malware families used by UNC5221 in Ivanti campaigns.

2.3.2.6 ZIPLINE

ZIPLINE is a passive backdoor that was used during Cutting Edge on compromised Secure Connect VPNs for reverse shell and proxy functionality.[1]

- **Threat Correlation:** Passive backdoor used in Secure Connect VPN exploitation; may overlap with Ivanti tooling.

2.3.2.7 BRICKSTORM

Brickstorm is a sophisticated and highly evasive cyberespionage backdoor tool, primarily associated with the China-aligned threat group UNC5221. The malware has been used in long-term espionage campaigns to infiltrate and steal intellectual property and other sensitive information from high-value targets, particularly in Europe.

- **Threat Correlation:** UNC5221-linked espionage tool; may be deployed post-access for long-term persistence.

2.3.2.8 EARTHWORM

is a simple network tunnel with SOCKS v5 sever and port transfer. It works well in various situations. It supports "forward", "backward" and "multi-transfer" modes and can penetrate deeply into the intranet. It supports various OS such as Linux, Windows, MacOS, Arm-Linux. Adversaries may tunnel network communications to and from a victim system within a separate protocol to avoid detection and network filtering, or to enable access to otherwise unreachable systems.

- **Threat Correlation:** Network tunneling tool; useful for C2 or lateral movement post-Ivanti compromise.

2.3.2.9 LIGHTWIRE

LIGHTWIRE is a web shell written in Perl that was used during Cutting Edge to maintain access and enable command execution by imbedding into the legitimate compcheckresult.cgi component of Ivanti Secure Connect VPNs.

- **Threat Correlation:** Web shell embedded in Ivanti CGI component; aligns with CVE-2024-21887 exploitation.

2.3.2.10 NEO-reGEORG

Neo-reGeorg is an open-source web shell designed as a restructuring of reGeorg with improved usability, security, and fixes for existing reGeorg bugs.

- **Threat Correlation:** Open-source web shell; commonly used in VPN appliance exploitation scenarios

2.3.3 MITRE ATT&CK Mapping for Ivanti CVEs



Tactic	Technique ID	Technique Name	Description
Initial Access	T1190	Exploit Public-Facing Application	Attackers exploit Ivanti VPN endpoints to gain unauthenticated access.
Execution	T1059.004	Command and Scripting Interpreter: Unix Shell	Shell commands injected via login.cgi to execute payloads like TRAILBLAZE.

Persistence	<u>T1505.003</u>	Server Software Component: Webshell	BRUSHFIRE backdoor embedded in /home/bin/web for long-term access.
Defense Evasion	<u>T1562.001</u>	Impair Defenses: Disable or Modify Tools	Ivanti's integrity checker tool (ICT) is tampered to avoid detection.
Command & Control	<u>T1071.001</u>	Application Layer Protocol: Web	BRUSHFIRE uses passive HTTP/S beaconing for stealthy C2 communication.
Credential Access	<u>T1003</u>	OS Credential Dumping	VPN session tokens and credentials are harvested post-exploitation.
Exfiltration	<u>T1041</u>	Exfiltration Over C2 Channel	Data exfiltrated via encrypted channels from compromised appliances.
Lateral Movement	<u>T1021.004</u>	Remote Services: SSH	SPAWN toolkit used to pivot across systems using SSH and remote shells.
Defense Evasion	<u>T1027</u>	Obfuscated Files or Information	TRAILBLAZE is packed and Base64-encoded in shell scripts.
Defense Evasion	<u>T1036</u>	Masquerading	BRUSHFIRE masquerades as legitimate SSL_read hook.
Defense Evasion	<u>T1222</u>	File and Directory Permissions Modification	Used to persist implants in /home/bin/web with modified perms.
Discovery	<u>T1016</u>	System Network Configuration Discovery	SPAWN tools perform network recon for lateral movement.
Discovery	<u>T1033</u>	System Owner/User Discovery	Used to identify privileged accounts post-access.
Discovery	<u>T1057</u>	Process Discovery	TRAILBLAZE targets running processes for injection.
Discovery	<u>T1082</u>	System Information Discovery	Recon phase includes OS fingerprinting.
Discovery	<u>T1083</u>	File and Directory Discovery	SPAWN tools enumerate file paths for implant placement.
Discovery	<u>T1518</u>	Software Discovery	SPAWNSLOTH disables dslogserver and remote syslog.
Execution	<u>T1047</u>	Windows Management Instrumentation	Used in lateral movement and remote command execution (especially in hybrid Windows environments).

TRAILBLAZE dropper, BRUSHFIRE backdoor, and SPAWN ecosystem

Linux. Windows. Network

10

Ivanti Exploitation Path

A

ion Guardrails

Security
Software Discovery

2.3.4 Risk Assessment

The following table outlines the potential risk and impact to PMG.

Category	Risk / Impact
Remote Access Compromise	VPN gateway exploitation allows attackers to bypass authentication and gain full access to internal systems.
Patient Data Exposure	Attackers can exfiltrate PHI (Protected Health Information), violating HIPAA and triggering breach notifications.
Malware Deployment	TRAILBLAZE and BRUSHFIRE enable stealthy persistence and remote control, often undetected by traditional AV.
Credential Theft	VPN session tokens and cached credentials can be harvested, enabling lateral movement and privilege escalation.
Operational Disruption	Attackers may disable logging (via SPAWNSLOTH), tamper with integrity tools, or crash services, impacting care delivery.
Compliance Violations	Failure to patch or detect exploitation could result in regulatory penalties and loss of accreditation.
Third-Party Risk	Compromised VPNs may be used to pivot into EHR systems, billing platforms, or partner networks.
Reputation Damage	Public disclosure of a breach tied to known CVEs can erode patient trust and damage institutional credibility.
Incident Response Overload	Without automation or SOAR playbooks, even a single compromise can overwhelm IT and compliance teams.

2.3.5 Recommendations for Mitigation and Detection

This section outlines high-level mitigation and detection strategies for Ivanti-related CVEs exploited by UNC5221. Detailed configuration guidance and workflow enhancements are provided in the accompanying solution document. Note that these recommendations include potential additions to the existing toolset.

These recommendations are intended for organizations currently using Ivanti products and may require adaptation based on individual infrastructure and security policies. For step-by-step implementation details and workflow integration, please refer to the accompanying solution document before making any changes.

2.3.5.1 Mitigation Recommendations

2.3.5.1.1 Patch Validation and Software Hygiene

- Validate all deployed Ivanti Connect Secure appliances against the latest vendor advisories.

- Ensure software versions meet or exceed the patch levels specified in the mitigation sections of CVE-2025-22457, CVE-2023-46805, and CVE-2024-21887.
- Monitor for out-of-band firmware updates and emergency hotfixes from Ivanti and CISA.

2.3.5.1.2 Asset Management and Attack Surface Reduction

- Use SentinelOne Ranger or equivalent tools to discover unmanaged or rogue VPN appliances, IoT devices, and remote endpoints.
- Maintain a centralized asset inventory that includes:
 - Network infrastructure (firewalls, switches, VPNs)
 - Server Compute
 - Medical devices and embedded systems
 - End-user workstations and mobile devices
 - Cloud workloads and virtual appliances
- Tag critical assets (VPN gateways, EHR systems) for prioritized alerting and patch enforcement.

2.3.5.1.3 Network Segmentation and Access Control

- Isolate Ivanti appliances from direct internet exposure where possible.
- Enforce strict ACLs and firewall rules to limit access to endpoints.
- Require MFA for all VPN access.

2.3.5.2 Detection Enhancements

2.3.5.2.1 Sigma Rule Deployment

Deployment of Sigma rules related to the CVEs. Sigma rules enhance log-based detection across multiple platforms. Recommended log sources include:

- **Windows Sysmon / Event Logs**
Detect shell execution, credential access, and process injection (e.g., TRAILBLAZE behavior).
- **Suricata IPS**
Match exploit signatures for login.cgi and welcome.cgi injection attempts. Use Sid 22457 for CVE-2025-22457.
- **Firewall Logs**
Adapt Sigma rules to detect anomalous outbound traffic, reverse shells, and passive beaconing.
- **Azure Security Center / Defender XDR**
Translate Sigma logic into KQL queries to detect command injection, webshell activity, and lateral movement.
- **Ivanti Connect Secure Logs**
Monitor HTTP access logs for exploit chains involving login.cgi, welcome.cgi, and suspicious POST bodies.
- **Splunk SIEM / SOAR**
Use Sigma2Splunk converters to build correlation searches, risk-based alerts, and automated playbooks.
- **SentinelOne Singularity Endpoint**
While Sigma is not natively supported, logic can be translated into Storyline Active Response (STAR) rules or hunting queries.
- **CrowdSec**
Convert Sigma rules into YAML-based scenarios. CrowdSec supports behavioral detection and can trigger bouncer actions (e.g., IP blocking, Discord alerts).

2.3.5.2.2 YARA Rule Deployment

YARA rules support malware identification, endpoint detection, and forensic triage. Recommended integrations:

- **SentinelOne Deep Visibility**
Scan memory and file artifacts for BRUSHFIRE, TRAILBLAZE, and SPAWN variants. Supports custom indicators.
- **Ivanti Connect Secure Appliance**
Use YARA to scan /home/bin/web and other implant paths if file access is available via SSH or forensic imaging.
- **Splunk**
Integrate YARA via scripted inputs or sandbox connectors (e.g., Cuckoo, VMRay) for malware analysis.
- **Microsoft Defender for Office 365**
Apply YARA in sandboxed email attachment analysis and phishing lure detection.
- **Azure Security Center / Defender for Endpoint**
Use YARA for file scanning and memory inspection across cloud workloads and hybrid endpoints.
- **DLP Solutions**
Apply YARA to scan outbound files for sensitive content (e.g., PHI, PII, credentials) before transmission

2.3.5.3 Additional Recommendations

- File Integrity Monitoring (FIM)
- SentinelOne enhancements
 - Ranger
 - STAR
- Passive DNS and Proxy Analysis
- Threat Intelligence enhancements, integration of existing tools and CrowdSec into current workflows.
- Deployment of Splunk SOAR as an enhancement to the existing toolset
 - Automate response actions such as:
 - Endpoint isolation
 - Ticket creation
 - Threat enrichment
 - SOC notification
- Deployment of a Data Loss Prevention (DLP) solution to add additional internal controls gear towards protecting sensitive data (HIPPA/PHI/PII)

3 SECURITY OPERATIONS CENTER - DETECTION STRATEGY AND RULE DEPLOYMENT

3.1 PURPOSE

This section outlines the detection logic, rule formats, and platform-specific integrations designed to identify exploitation attempts and post-compromise activity related to CVE-2025-22457, CVE-2023-46805, and CVE-2024-21887. The rules can be deployed across a multi-platform SOC environment, including SentinelOne, Splunk, CrowdSec, Suricata, and DLP solutions. Each rule is mapped to MITRE ATT&CK techniques and aligned with the threat intelligence findings in Section 2. The goal is to provide reproducible detection logic that supports both automated response and forensic triage.

3.2 CRITICAL LOG SOURCES AND TELEMETRY

3.2.1 Critical Log Sources

Category	Source	Why It's Critical
VPN Gateway Logs	Ivanti Connect Secure HTTP access logs (welcome.cgi, login.cgi, DSID cookies)	Detects initial access, exploit attempts, and webshell injection (T1190, T1059.004)
Web Server Logs	Webserver(s) logs on Ivanti appliance or reverse proxy	Captures command injection, unusual POSTs, and shell payloads
Process Creation	Sysmon (Windows), auditd (Linux), SentinelOne Deep Visibility	Detects TRAILBLAZE execution, shell spawns, and BRUSHFIRE injection (T1059.004, T1057)
File Integrity Monitoring	SentinelOne	Flags changes to /home/bin/web, dropped implants, or tampered ICT binaries (T1505.003, T1222)
Network Traffic	Suricata/Snort, firewall logs, CrowdSec decisions	Identifies passive beaconing, reverse shells, and lateral movement (T1071.001, T1021.002)
Authentication Logs	VPN login events, AD/LDAP logs, MFA failures	Detects credential harvesting, session hijacking, and brute force attempts (T1003, T1033)
Endpoint Telemetry	SentinelOne, Defender for Endpoint, CrowdSec agent	Tracks shell execution, memory-only payloads, and suspicious child processes
DNS & Proxy Logs	Internal DNS, web proxy, Secure Web Gateway	Reveals C2 domains, encoded payloads, and exfiltration attempts (T1041)

Email Security Logs	Defender for O365	Detects phishing lures targeting VPN credentials or fake Ivanti updates
Asset Inventory & Vulnerability Scans	Qualys, SentinelOne Ranger	Identifies vulnerable Ivanti appliances and unmanaged VPN endpoints
Cloud App Logs	Azure App Service, Defender for Cloud	Detects command injection patterns (cmd=, ;, &) in cloud-exposed Ivanti services

3.2.2 MITRE Technique Telemetry Coverage

MITRE Technique	Required Telemetry
T1190 – Exploit Public-Facing App	VPN logs, web server logs
T1059.004 – Unix Shell	Process creation, shell history
T1505.003 – Webshell	File integrity, process injection
T1562.001 – Disable Security Tools	ICT tampering, log suppression
T1071.001 – Web C2	Firewall / IPS (Suricata) logs
T1003 – Credential Dumping	EDR/Auth logs, memory inspection
T1041 – Exfiltration	DNS, firewall logs
T1021.004 – SSH	Network traffic, process logs
T1033 – User Discovery	Endpoint telemetry, shell history
T1222 – File Permissions	FIM, auditd, SentinelOne
T1518.001 – Security Software Discovery	Process logs, endpoint scans
T1027 – Obfuscated Files or Information	File content inspection, script decoding, memory analysis
T1036 – Masquerading	Process lineage, binary metadata, DLL loading anomalies
T1016 – System Network Configuration Discovery	Network interface logs, shell commands (ip, ifconfig)
T1057 – Process Discovery	Process listings, auditd
T1082 – System Information Discovery	OS fingerprinting, hostname queries, system metadata
T1083 – File and Directory Discovery	File access logs, shell history, auditd

3.3 DETECTION RULE SUGGESTIONS

3.3.1 YARA Rules for Detection



This section outlines YARA-based detection logic for identifying memory-resident implants and file-based indicators. These rules can be applied across the security stack, SentinelOne, Microsoft Defender, DLP solutions and forensic platforms.

- BRUSHFIRE Dropper

```
rule BRUSHFIRE_Backdoor
{
  meta:
    description = "Detects BRUSHFIRE passive backdoor"
    author = "Paul Leone"
    cve = "CVE-2025-22457"
  strings:
    $s1 = "BRUSHFIRE::init"
    $s2 = "/home/bin/web"
    $s3 = "passive_beacon_mode"
  condition:
    all of them
}
```

- SPAWN Toolset

```
rule M_APT_Installer_SPAWNANT_1
{
  meta:
    author = "Mandiant"
    description = "Detects SPAWNANT. SPAWNANT is an
Installer targeting Ivanti devices. Its purpose is to
persistently
install other malware from the SPAWN family (SPAWNSNAIL,
SPAWNMOLE) as well as drop additional webshells on the
box."

  strings:
    $s1 = "dspkginstall" ascii fullword
    $s2 = "vsprintf" ascii fullword
    $s3 = "bom_files" ascii fullword
    $s4 = "do-install" ascii
    $s5 = "ld.so.preload" ascii
    $s6 = "LD_PRELOAD" ascii
    $s7 = "scanner.py" ascii

  condition:
    uint32(0) == 0x464c457f and 5 of ($s*)
}
```

```

rule M_Utility_SPAWNSNARE_1 {
  meta:
    author = "Mandiant"
    description = "SPAWNSNARE is a utility written
in C that targets
Linux systems by extracting the uncompressed Linux
kernel image
into a file and encrypting it with AES."

  strings:
    $s1 = "\x00extract_vmlinux\x00"
    $s2 = "\x00encrypt_file\x00"
    $s3 = "\x00decrypt_file\x00"
    $s4 = "\x00lbb_main\x00"
    $s5 = "\x00busybox\x00"
    $s6 = "\x00/etc/busybox.conf\x00"

  condition:
    uint32(0) == 0x464c457f
    and all of them
}

```

```

rule M_APT_Utility_SPAWNSLOTH_2
{
  meta:
    author = "Mandiant"
    description = "Hunting rule to identify strings
found in SPAWNSLOTH"

  strings:
    $dslog = "dslogserver" ascii fullword
    $hook1 = "g_do_syslog_servers_exist" ascii
fullword
    $hook2 = "ZN5DSLog4File3addEPKci" ascii fullword
    $hook3 = "funchook" ascii fullword

  condition:
    uint32(0) == 0x464c457f and all of them
}

```

3.3.2 Suricata Intrusion Prevention System Detection Rules

- Exploit Attempt



```

alert http $EXTERNAL_NET any -> $HOME_NET any (msg:"Ivanti CVE-2025-22457 Exploit Attempt";
flow:to_server,established; content: "/dana-na/auth/url_default/welcome.cgi"; http_uri;
content: "TRAILBLAZE"; http_client_body; classtype:attempted-admin; sid:22457; rev:1;)

```

- Shell Dropper Detection

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 443 (msg:"Ivanti CVE-2025-22457 Shell Dropper";
flow:to_server,established; content:"#!/bin/sh"; content:"TRAILBLAZE"; content:"BRUSHFIRE";
sid:224572025; rev:1;)
```

3.3.3 SentinelOne



SentinelOne

Recommended enhancements to SentinelOne Singularity Endpoint that strengthen detection and response for Ivanti-related threats:

- **Deep Visibility**

Enables granular telemetry across endpoints, capturing process execution, memory artifacts, and file operations — essential for detecting in-memory payloads like TRAILBLAZE and stealthy implants like BRUSHFIRE.

3.3.4 CrowdSec Detection Scenarios



CrowdSec scenarios use YAML rules to analyse logs and trigger actions. They work with web, VPN, and optionally Suricata logs to spot brute force and exploit attempts. You can also set up remediation nodes for automatic rule updates with known C2 IPs.

- Scenario: Ivanti Auth Bypass via DSID Cookie

```
name: crowdsecurity/ivanti-auth-bypass
description: Detects suspicious DSID cookie usage targeting Ivanti welcome.cgi
filter: |
  evt.Meta.log_type == 'http_access-log' &&
  Lower(evt.Meta.http_path) contains "/dana-na/auth/url_default/welcome.cgi" &&
  Lower(evt.Meta.http_cookie) contains "dsid="
groupby: evt.Meta.source_ip
distinct: evt.Meta.http_cookie
capacity: 5
leakspeed: 10m
labels:
  type: exploit
  remediation: true
  classification:
    - attack.initial_access
    - cve.CVE-2023-46805
```

- Scenario: Ivanti Command Injection via login.cgi

```
name: crowdsecurity/ivanti-command-injection
description: Detects suspicious cmd= injection attempts in Ivanti login.cgi
filter: |
  evt.Meta.log_type == 'http_access-log' &&
  Lower(evt.Meta.http_path) contains "/dana-na/auth/url_default/login.cgi" &&
  Lower(evt.Meta.http_body) contains "cmd=" &&
  (
    Lower(evt.Meta.http_body) contains "%3b" or
    Lower(evt.Meta.http_body) contains "%26" or
    Lower(evt.Meta.http_body) contains "%2f"
  )
groupby: evt.Meta.source_ip
distinct: evt.Meta.http_body
capacity: 3
leakspeed: 5m
labels:
  type: exploit
  remediation: true
  classification:
    - attack.execution
    - cve.CVE-2024-21887
```

- Scenario: Ivanti Custom Detection for CVE-2025-22457 / TRAILBLAZE

```
name: crowdsec/ivanti_cve_2025_22457
description: Detects exploitation attempts of CVE-2025-22457
filter: |
  evt.Meta.service == "http" &&
  evt.Meta.http_path contains "/dana-na/auth/url_default/welcome.cgi" &&
  evt.Meta.http_body contains "TRAILBLAZE"
groupby: evt.Meta.source_ip
blackhole: 5m
labels:
  type: exploit
  remediation: true
  classification: CVE-2025-22457
```

3.3.5 Firewall Filter Rules

CrowdSec remediation service deployed on the NG Firewall can ingest firewall rules via packages or block lists.

Firewall / Rules / LAN

FloatingTailscaleWANLANSYNCLANVPN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
	0/1.82 MiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	
	0/32 KiB	IPv4 *	*	*	pfB_PRI1_v4						
	0/0 B	IPv4 *	*	*	crowdsec6_blacklists						
	0/660 B	IPv4 *	*	*	crowdsec_blacklists						
192.168.100.0/24 rules											
	0/75.54 MiB	IPv4 *	192.168.100.15	*	192.168.1.3						
	0/0 B	IPv4 *	192.168.100.15	*	192.168.1.247	*	*	none			

Alias details

Value	Description
45.9.148.120	UNC5221 Reported in Ivanti exploitation campaigns
103.27.186.11	APT41 (China) Used in multiple supply chain intrusions
185.220.101.26	Sandworm (Russia) Linked to VPNFilter and ICS targeting
91.212.124.159	Turla (Russia) Known C2 infrastructure for watering hole ops
203.131.222.10	Lazarus Group (North Korea) Used in financial and healthcare targeting
82.118.21.1	APT28 (Russia) Associated with phishing and credential theft
192.42.116.41	Mustang Panda (China) Used in malware delivery and C2
104.244.75.98	APT10 (China) Cloudhopper campaign infrastructure
176.123.2.50	Gamaredon (Russia) Used in phishing and remote access campaigns

Example of deployed Scenarios

Scenario	Status	Version	Description
crowdsecurity/CVE-2017-9841	enabled	0.2	Detect CVE-2017-9841 exploits
crowdsecurity/CVE-2019-18935	enabled	0.2	Detect Telerik CVE-2019-18935 exploitation attempts
crowdsecurity/CVE-2022-26134	enabled	0.4	Confluence - RCE (CVE-2022-26134)
crowdsecurity/CVE-2022-35914	enabled	0.2	Detect CVE-2022-35914 exploits
crowdsecurity/CVE-2022-37042	enabled	0.2	Detect CVE-2022-37042 exploits
crowdsecurity/CVE-2022-40684	enabled	0.3	Detect cve-2022-40684 exploitation attempts
crowdsecurity/CVE-2022-41082	enabled	0.4	Detect CVE-2022-41082 exploits
crowdsecurity/CVE-2022-41697	enabled	0.2	Detect CVE-2022-41697 enumeration
crowdsecurity/CVE-2022-42889	enabled	0.3	Detect CVE-2022-42889 exploits (Text4Shell)
crowdsecurity/CVE-2022-44877	enabled	0.3	Detect CVE-2022-44877 exploits
crowdsecurity/CVE-2022-46169	enabled	0.2	Detect CVE-2022-46169 brute forcing
crowdsecurity/CVE-2023-22515	enabled	0.1	Detect CVE-2023-22515 exploitation
crowdsecurity/CVE-2023-22518	enabled	0.3	Detect CVE-2023-22518 exploits
crowdsecurity/CVE-2023-49103	enabled	0.3	Detect owncloud CVE-2023-49103 exploitation attempts
crowdsecurity/CVE-2024-0012	enabled	0.1	Detect CVE-2024-0012 exploitation attempts
crowdsecurity/CVE-2024-38475	enabled	0.1	Detect CVE-2024-38475 exploitation attempts

3.3.6 File Integrity Monitoring (FIM)

- Monitor critical paths such as /home/bin/web, /tmp/, and /var/log/ for unauthorized changes, implant drops, and log tampering.
- Use cases:
 - **SentinelOne** for kernel-level monitoring and behavioral detection of file modifications.
 - **CrowdSec** to detect suspicious file access patterns and correlate with behavioral scenarios (e.g., unexpected shell activity or log suppression).
 - **Splunk SOAR** to ingest FIM alerts and trigger automated playbooks (e.g., isolate asset, enrich with threat intel, notify SOC).

3.3.7 Passive DNS and Proxy Analysis

- Track outbound connections to known C2 domains used by BRUSHFIRE, ZIPLINE, and other UNC5221 tooling.
- Flag:
 - Encoded payloads (e.g., Base64 in HTTP POST bodies)
 - Suspicious user agents (e.g., curl, wget, custom implants)

3.3.8 Sigma Rules and Splunk Correlation Logic



These queries and rules are designed to detect Ivanti exploitation activity across multiple stages of the kill chain, from initial access to post-exploitation. They correlate logs from:

- Ivanti VPN appliances (e.g., login.cgi, welcome.cgi)
- Suricata alerts (network-based IDS signatures)
- System audit logs (Windows Sysmon, Linux auditd)

Each Search Processing Language (SPL) query or rule targets specific behaviors:

- Webshell drop detection (e.g., TRAILBLAZE payloads)
 - Suricata alert correlation for CVE-specific signatures
 - Post-exploitation activity like file creation and beaconing
- Sigma Rule (Webshell Drop via Ivanti Exploit)

```
title: Ivanti Connect Secure Webshell Drop
id: 9e8b3c3e-4685-4c87-9f3e-ivanti-webshell
status: experimental
description: Detects suspicious file creation in Ivanti Connect Secure
directories
logsource:
  product: windows
  category: file_create
detection:
  selection:
    TargetFilename|contains:
      - '\temp\'
      - '\htdocs\'
    Image|contains:
      - 'cmd.exe'
      - 'powershell.exe'
  condition: selection
fields:
  - TargetFilename
  - Image
  - User
  - CommandLine
level: high
tags:
  - attack.initial_access
  - attack.persistence
  - cve.CVE-2023-46805
  - cve.CVE-2024-21887
```

- Splunk Alert and Query Translations (Webshell Drop via Ivanti Exploit)

```
[Ivanti Connect Secure Webshell Drop]
alert.severity = 4
description = Detects suspicious file creation in Ivanti Connect Secure
directories (Rule ID: 9e8b3c3e-4685-4c87-9f3e-ivanti-webshell) Reference:
https://tdm.socprime.com/tdm/info/
cron_schedule = 0 * * * *
disabled = 1
is_scheduled = 1
is_visible = 1
dispatch.earliest_time = -60m@m
dispatch.latest_time = now
search = index=* source="WinEventLog:*" AND ((TargetFilename="*\\temp\\" OR
TargetFilename="*\\htdocs\\") AND (NewProcessName="*cmd.exe*" OR
NewProcessName="*powershell.exe*)) | table
TargetFilename,NewProcessName,User,CommandLine
alert.suppress = 0
alert.track = 1
actions = risk,notable
action.risk = 1
action.risk.param._risk_object_type = user
action.risk.param._risk_score = 75
action.correlationsearch = 0
action.correlationsearch.enabled = 1
action.notable.param.rule_title = Ivanti Connect Secure Webshell Drop
action.notable.param.rule_description = Detects suspicious file creation in
Ivanti Connect Secure directories (Rule ID: 9e8b3c3e-4685-4c87-9f3e-ivanti-
webshell)
```

```
index=* source="WinEventLog:*" AND ((TargetFilename="*\\temp\\" OR
TargetFilename="*\\htdocs\\") AND (NewProcessName="*cmd.exe*" OR
NewProcessName="*powershell.exe*)) | table
TargetFilename,NewProcessName,User,CommandLine
```

- Ivanti Exploit Chain Detection (Webshell Drop)

```
index=web_logs sourcetype=ivanti_http_logs
| search uri="/dana-na/auth/url_default/welcome.cgi" AND cookie="DSID="
| join source_ip [ search index=web_logs uri="/dana-
na/auth/url_default/login.cgi" body="cmd=" OR body="TRAILBLAZE" ]
| stats count by source_ip, uri, user_agent, body
| where count > 2
```

- Suricata Alert Correlation (Sid 468051 + 218871 + 22457)

```
index=suricata sourcetype=suricata_eve
| search alert.signature IN (
    "EXPLOIT - Ivanti Connect Secure Authentication Bypass",
    "EXPLOIT - Ivanti Connect Secure Command Injection",
    "EXPLOIT - Ivanti Connect Secure Buffer Overflow CVE-2025-22457"
)
| stats count by src_ip, dest_ip, alert.signature, timestamp
| where count > 1
```

- File Creation + Network Beaconing (Post-Exploitation)

```
index=os_logs sourcetype=linux_audit OR sourcetype=windows_sysmon
| search process_name="cmd.exe" OR process_name="powershell.exe" OR
process_name="TRAILBLAZE"
| join host [ search index=network_logs dest_port=443 OR dest_port=8443 ]
| stats count by host, process_name, dest_ip, uri
| where count > 3
```

3.4 WORKFLOW AND FEATURE ENHANCEMENTS TO EXISTING SOLUTIONS

3.4.1 SentinelOne Singularity Endpoint

Recommended enhancements to SentinelOne that provide increased asset visibility and streamline workflows for Ivanti-related threats:

- **Device Inventory**

Automatically discovers and tracks all endpoints, including Windows, Linux, macOS and cloud workloads. Displays hostname, OS, IP, MAC address, agent status and more. Tag assets by site, group, policy, and criticality level for triage and prioritization.

- **Ranger**

Performs passive network discovery to identify unmanaged or rogue devices, including vulnerable Ivanti VPN appliances. Helps map the full attack surface and flag assets missing endpoint protection. Supports agentless visibility using passive network scanning.

- **STAR (Storyline Active Response)**

SentinelOne's custom detection engine that correlates process chains, flags suspicious behavior (shell spawn from web process), and automates response actions like isolation, alerting, and enrichment.

- Create custom STAR detection rules for suspicious behaviors linked to these CVEs:

Rule: Suspicious Webshell Drop

ProcessName: powershell.exe OR cmd.exe
CommandLine: contains "echo" AND contains ".aspx" OR ".jsp"
ParentProcess: httpd.exe OR nginx.exe OR unknown
Tags: ["ivanti", "webshell", "CVE-2023-46805"]

Rule: Command Injection via login.cgi

ProcessName: bash OR sh OR python
CommandLine: contains "cmd=" AND contains ";"
ParentProcess: httpd OR nginx OR unknown
Tags: ["ivanti", "command-injection", "CVE-2024-21887"]

Rule: Buffer Overflow Dropper

ProcessName: cmd.exe OR powershell.exe OR TRAILBLAZE
CommandLine: contains "BRUSHFIRE" OR "/home/bin/web"
ParentProcess: httpd OR nginx OR unknown
Tags: ["ivanti", "dropper", "CVE-2025-22457"]

- Storyline Correlation Logic:
 - Web process spawning shell interpreters
 - Encoded payloads (e.g., base64, PowerShell) from web-facing services
 - Outbound HTTPS connections from non-browser processes

Example:

- httpd.exe → powershell.exe → curl.exe → remote IP

- Flag this as suspicious lateral movement or C2 beaconing.
- httpd.exe → TRAILBLAZE → BRUSHFIRE → outbound HTTPS
- Memory-only execution with no file artifacts
- Reverse shell or passive beaconing from /home/bin/web

3.4.2 SOAR Playbooks

Integrating a SOAR platform into the current SOC toolset will facilitate the automation of response actions across multiple platforms.

- **Endpoint Isolation**
 - Trigger via SentinelOne or Defender for Endpoint.
 - Use Splunk SOAR to orchestrate across hybrid environments.
- **Ticket Creation**
 - Auto-generate tickets in ITSM platforms (ServiceNow, Jira) with full context from CrowdSec, SentinelOne, and Splunk.
- **Threat Enrichment**
 - Pull CVE metadata, MITRE mappings, and malware family details into alert context.
 - Use Splunk SOAR to enrich alerts with Sigma/YARA matches and IOC overlays.
- **SOC Notification**
 - Send real-time alerts to Slack, Teams, or email with full triage context.
 - Include asset tags, exploit chain stage, and recommended response actions.
- **Ivanti-Specific Logic**
 - Detect access to /dana-na/auth/url_default/login.cgi with cmd= or TRAILBLAZE payloads.
 - Flag modifications to /home/bin/web and disablement of dslogserver.
 - Correlate with Suricata Sid 22457 and CrowdSec exploit scenarios.

3.4.3 Threat Intelligence Integration

- Enrich detections with IOCs from:
 - CISA AA25-22457
 - Health-ISAC
 - Commercial feeds (Recorded Future, Proofpoint, SentinelOne Threat Intel)
- Use cases:
 - **Splunk SOAR** to ingest threat intel feeds and correlate with asset criticality, MITRE techniques, and recent alerts.

- **SentinelOne STAR** to tag assets and apply custom detection logic based on threat indicators.
- **CrowdSec** to ingest IOCs into its decision engine and trigger bouncer actions (e.g., IP block, Discord alert).
- **DLP solution** to apply threat intel to outbound file scanning and block transmission of known malware or sensitive content.

3.4.4 Passive DNS and Proxy Analysis

- Workflow use cases:
 - CrowdSec to detect repeated outbound attempts, DNS tunneling, or proxy evasion. CrowdSec scenarios can block IPs and log decisions for SOC review.
 - Splunk SOAR to correlate proxy anomalies with endpoint behavior (e.g., shell spawn → outbound HTTPS → C2 domain).
 - DLP solution to inspect outbound traffic for sensitive data exfiltration (e.g., PHI, credentials) and enforce transmission policies.

3.4.5 Integration Notes

- **Splunk SOAR** can ingest alerts from Sigma, Suricata, CrowdSec, and YARA-based sandboxing tools to automate triage, ticketing, and endpoint isolation. SOAR playbooks can trigger based on Sigma-matched alerts
- **SentinelOne STAR** can be enriched with YARA hits and CrowdSec decisions to trigger behavioral response actions.
- **CrowdSec** scenarios can be mapped to MITRE techniques and used to block IPs, trigger alerts, or forward decisions to SIEM/SOAR platforms.
- **DLP solutions** (Microsoft Purview, CoSoSys, Forcepoint) can apply YARA rules to scan outbound files for implants or sensitive content.

3.5 NEW PLATFORM AND TECHNOLOGY ACQUISITIONS

3.5.1 CrowdSec Threat Intelligence



Deploying CrowdSec introduces a collaborative, behavior-based defense layer that strengthens detection and response across network and system activity. It's especially valuable for small healthcare organizations seeking lightweight, scalable protection against exploitation attempts, credential abuse, and lateral movement, including those tied to CVE-2025-22457, CVE-2023-46805, and CVE-2024-21887.

Options include: CrowdSec Community Edition (free), CrowdSec Premium (with extended telemetry and support)

Key Capabilities to Prioritize:

- **Behavioral Detection:**
Detect brute force, command injection, and suspicious shell activity using YAML-based scenarios mapped to MITRE techniques.

- **Log Source Integration:**
Ingest logs from firewalls, VPNs, Suricata, SSH, and systemd to monitor for Ivanti-specific exploit chains and post-exploitation behavior.
- **Bouncer Actions:**
Automatically block malicious IPs, disable user accounts, or trigger alerts based on real-time decisions.
- **Community Threat Intelligence:**
Leverage global signals from other CrowdSec users to enrich local detections and prioritize emerging threats.
- **Sigma Rule Conversion:**
Translate Sigma rules into CrowdSec scenarios to detect known attack patterns and anomalies.
- **SOAR Integration:**
Forward CrowdSec decisions to Splunk SOAR for automated triage, ticketing, and enrichment alongside SentinelOne and DLP alerts.

Strategic Benefits:

- Adds real-time behavioral detection to VPN and endpoint telemetry.
- Enables automated blocking of known malicious IPs and exploit attempts.
- Provides community-driven threat intelligence without heavy infrastructure.
- Enhances visibility into Ivanti-related attack flows with minimal overhead.

3.5.2 Splunk SOAR



Deploying Splunk SOAR enables automated, scalable incident response tailored to healthcare environments. It's especially critical when facing multi-stage attacks like those exploiting Ivanti VPN infrastructure, where rapid triage and coordinated response are essential.

Options include: Splunk SOAR Cloud, Splunk SOAR On-Prem, or Splunk SOAR Lite for smaller teams

Key Capabilities to Prioritize:

- **Playbook Automation:**
Build workflows to isolate endpoints, enrich alerts, notify SOC teams, and escalate incidents based on severity and asset criticality.
- **Threat Intelligence Correlation:**
Integrate feeds from CISA, Health-ISAC, SentinelOne, CrowdSec, and DLP tools to enrich alerts with CVE, malware, and MITRE context.
- **Asset-Aware Response:**
Tag critical assets (VPN gateways, EHR systems) and prioritize response actions accordingly.
- **IOC Matching and Enrichment:**
Automatically match incoming alerts against known indicators (BRUSHFIRE domains, ZIPLINE hashes) and enrich with MITRE technique mappings.

- **Cross-Platform Integration:**
Connect with SentinelOne, Microsoft Defender, CrowdSec, Qualys, and DLP tools to orchestrate unified response.
- **Case Management and Reporting:**
Track incident lifecycle, generate audit-ready reports, and support HIPAA compliance documentation.

Strategic Benefits:

- Enables rapid containment of Ivanti-related threats across endpoints, networks, and cloud.
- Reduces SOC fatigue through automated triage and enrichment.
- Ensures consistent, policy-driven response across all security tools.
- Supports forensic investigation and compliance reporting for PHI/PII incidents.

3.5.3 DLP solution



Implementing a DLP solution introduces critical internal controls designed to protect sensitive healthcare data, including HIPAA-regulated PHI, PII, and financial records. This is especially vital in the context of Ivanti exploitation, where attackers may gain access to VPN-connected endpoints and attempt data exfiltration.

Options include: Microsoft Purview, CoSoSys and Forcepoint DLP for small organizations.

Key Capabilities to Prioritize:

- **Content Inspection:**
Deep scanning of files, emails, and web uploads for sensitive data.
- **Policy Enforcement:**
Block or quarantine outbound transmissions that violate data handling policies, especially from compromised endpoints or VPN sessions.
- **Endpoint Integration:**
Monitor clipboard activity, USB transfers, and file access on workstations and mobile devices. Detect attempts to move PHI outside approved channels.
- **Network DLP:**
Inspect outbound traffic for encrypted payloads, ZIPLINE-style reverse shells, or BRUSHFIRE beacons that may contain exfiltrated data.
- **YARA Rule Support:**
Apply custom YARA rules to scan for malware-laced documents or implants attempting to masquerade as legitimate healthcare files.
- **SOAR Integration:**
Forward DLP alerts to Splunk SOAR for automated triage, ticketing, and endpoint isolation. Include context from CrowdSec decisions and SentinelOne Deep Visibility.

Strategic Benefits:

- Prevents unauthorized transmission of PHI/PII during or after exploitation of VPN infrastructure.
- Adds a compensating control for organizations with limited segmentation or endpoint hardening.
- Enables forensic triage of suspected data theft attempts tied to CVE-2025-22457, CVE-2023-46805, and CVE-2024-21887.

3.6 DETECTION RULE SUMMARY TABLE

Rule Type	Target Platform(s)	CVE Coverage	MITRE Technique(s)	Detection Purpose
YARA	SentinelOne, Defender, DLP	CVE-2025-22457	T1059.004, T1505.003	Detect BRUSHFIRE and SPAWN implants
Sigma	Splunk, CrowdSec	CVE-2023-46805, 2024-21887	T1190, T1071.001	Detect Ivanti exploit chains and webshells
Suricata	Suricata, CrowdSec	CVE-2025-22457	T1190, T1059.004	Detect buffer overflow and shell dropper
CrowdSec	CrowdSec, Splunk SOAR	All three CVEs	T1190, T1059.004	Detect command injection and auth bypass

This table supports SOC onboarding, dashboard filtering, and cross-platform rule deployment.